

SalesVerse 2.0

Production Support Handover

Support model, service levels, operating procedures, runbooks, configuration reference and knowledge transfer

IIFT Agent/Banca Portal & Back-office for Insurans Islam Family Takaful Sendirian Berhad



PREPARED FOR

Insurans Islam Family Takaful Sendirian Berhad

Bandar Seri Begawan, Brunei Darussalam

PREPARED BY

iorta TechNXT

<https://iortatechnxt.com>

Document reference	IIFT-SV2-PSH
Version	1.0
Date	October 2026
RFP deliverable	DEL-26 (Technical manual), DEL-27 (Operations manual), MNT-01 to MNT-30
Status	Issued with the proposal
Classification	Commercial-in-Confidence

Commercial-in-Confidence. Prepared by iorta TechNXT for Insurans Islam Family Takaful Sendirian Berhad as part of the response to IIFT's Request for Proposal for an Agent/Banca Portal and Back-office solution. Not to be disclosed to third parties without prior written consent.

Document Control

This document hands over the operation of SalesVerse 2.0 to the support organisation. It defines who does what, the service levels, the processes for incidents, problems, changes and releases, and gives the runbooks and reference data that support staff need. It is updated after every release (MNT-27).

Version history

Version	Date	Author	Description
0.9	September 2026	iorta TechNXT	Internal technical review
1.0	October 2026	iorta TechNXT	Issued with the tender proposal

Review and approval

Role	Name	Signature / date
Prepared by (Solution Architect, iorta TechNXT)	[Name]	
Reviewed by (Engineering Lead, iorta TechNXT)	[Name]	
Approved by (Project Director, iorta TechNXT)	[Name]	
Accepted by (IIFT IT)	[Name, designation]	

Document pack

Reference	Document	RFP deliverable	Status
IIFT-SV2-SAD	SalesVerse 2.0 Solution Architecture	DEL-06	Issued
IIFT-SV2-DD	SalesVerse 2.0 Data Dictionary	DEL-07	Issued
IIFT-SV2-PSH	SalesVerse 2.0 Production Support Handover	DEL-26, DEL-27, MNT-28	This document
IIFT-SV2-CSQ	SalesVerse 2.0 Code Standards & Quality Report	DEL-11, NFR-14	Issued
IIFT-SV2-SAR	SalesVerse 2.0 Security Assessment Report	DEL-17, NFR-13	Issued

Related material

- SalesVerse-2.0-Solution-Architecture: design, deployment, sizing and security.
- SalesVerse-2.0-Data-Dictionary: database tables and columns.
- README.md and apps/api/.env.example in the source repository.

Conventions

- Monetary amounts are in Brunei dollars (B\$). Times are Brunei time (UTC+8) unless marked UTC.
- RFP requirement identifiers (AP, BO, INT, COM, NFR, DEL, MNT) refer to IIFT's Request for Proposal. COM-01 to COM-10 in this pack are the shared platform requirements of RFP section 4.4.
- Items marked **delivered during implementation** are designed here but not yet present in the working application; everything else describes the application as it runs today.
- Text in [square brackets] is to be completed with IIFT during mobilisation.

Contents

Document Control.....	2
Contents.....	3
1. Introduction.....	5
2. Support Model.....	6
2.1 Channels.....	6
2.2 Responsibilities.....	6
3. Support Hours and Service Levels.....	8
3.1 Support hours.....	8
3.2 Severity definitions and SLA.....	8
4. Incident Management.....	9
4.1 P1 procedure.....	9
5. Problem Management.....	10
6. Change Management.....	11
7. Release Management.....	11
8. Escalation Matrix.....	12
9. Monitoring and Alerting.....	13
9.1 Health endpoints and metrics.....	13
9.2 Logs.....	13
9.3 Alerts.....	13
9.4 Daily health check.....	14
10. Operational Runbooks.....	15
10.1 R1 Start and stop the service.....	15
10.2 R2 Deploy a release with database migrations.....	15
10.3 R3 Roll back a release.....	16
10.4 R4 Rotate secrets and keys.....	16
10.5 R5 Restore from backup.....	16
10.6 R6 Re-run end-of-day.....	17
10.7 R7 Retry integration messages.....	17
10.8 R8 Unlock a user or reset a password.....	18
10.9 R9 Lift an agency issuance block.....	18
10.10 R10 Replace an AML watch-list.....	18
10.11 R11 Apply a product rate change.....	19
10.12 R12 Investigate an error reported by a user.....	19
11. Backup and Disaster Recovery.....	20
11.1 Backup schedule.....	20
11.2 Targets.....	20

11.3 Database failover to the local standby.....	20
11.4 DR invocation.....	21
11.5 Test schedule.....	21
12. Configuration Reference.....	22
12.1 Business parameters.....	24
13. Scheduled Jobs.....	25
14. Knowledge Transfer Plan.....	26
15. Developer Onboarding Guide.....	27
15.1 Repository layout.....	27
15.2 Local set-up.....	27
15.3 Scripts.....	27
15.4 Coding conventions.....	28
15.5 How to.....	28
16. Handover Checklist.....	30
17. Monthly Service Report Template.....	31
18. Exit and Transition Plan.....	31

1. Introduction

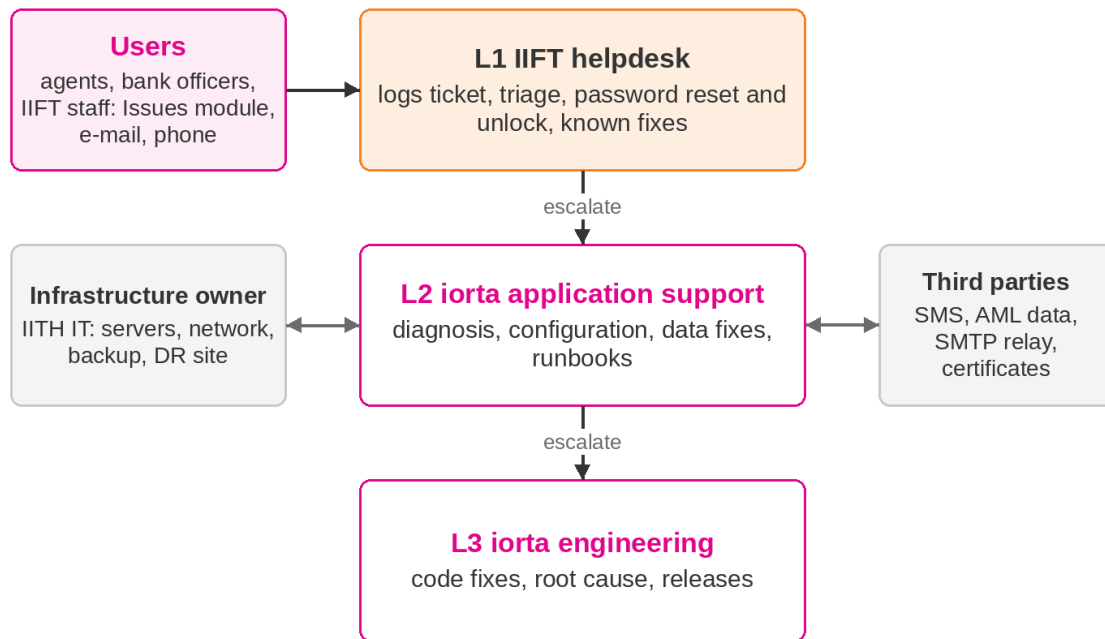
SalesVerse 2.0 goes live after UAT sign-off and is followed by four weeks of hypercare, during which the project team supports production directly. At hypercare exit the service moves to the support model in this document for the five-year maintenance period. The six-month warranty from go-live runs in parallel and covers defect correction at no cost.

Phase	Period	Support arrangement
Hypercare	Weeks 25 to 28 (4 weeks after go-live)	Project team on site or on call; daily stand-up with IIFT; priority fixes
Warranty	6 months from go-live	Defects fixed free of charge under this support model
Maintenance	Years 1 to 5 from go-live	This support model, SLA and monthly reporting

Table 1: Support phases

Readers: IIFT helpdesk and IT, IITH infrastructure, iorta support and engineering. Commands assume a Linux shell on the application or database VM, with the repository's deploy directory as working directory for Docker Compose commands.

2. Support Model



P1 incidents: telephone the on-call L2 engineer at any hour, and log a ticket.

Figure 1: Support tiers

Tier	Team	Responsibilities	Hours
L1	IIFT helpdesk	Receives calls, e-mails and Issues-module tickets; classifies priority; answers how-to questions; resets passwords and unlocks users; checks known errors; escalates with the correlation id	IIFT business hours; P1 on-call per IIFT rota
L2	iorta application support	Diagnoses from logs, metrics and data; runs runbooks; configuration and parameter changes; data corrections under change control; integration retries; coordinates with IITH IT	IIFT business hours; P1 24 x 7 on call
L3	iorta engineering	Code defects, root-cause analysis, fixes, performance work, releases and emergency patches	Business hours; P1 24 x 7 when escalated
Infra	IITH IT (infrastructure owner)	Servers, storage, network, firewalls, load balancers, operating systems, backup infrastructure, DR site, certificates, DNS, SMTP relay	Per IITH service hours

Table 2: Support tiers

2.1 Channels

- **Issues module** in the portal and back-office (preferred): records priority, category, attachments and SLA timers automatically.
- **Support e-mail** [support mailbox] for users without portal access; the helpdesk logs the ticket.
- **Telephone hotline** [number] for P1: always call in addition to logging a ticket.
- Every error screen shows a reference (the correlation id). Users quote it; support searches logs and the audit trail with it.

2.2 Responsibilities

Activity	IIFT helpdesk / IT	iorta L2	iorta L3	IITH infra
Log and classify incidents	R/A	C	I	I
User administration, unlock, password reset	R/A	C	–	–

Activity	IIFT helpdesk / IT	iorta L2	iorta L3	IITH infra
Business parameter and master data changes	A	R	–	–
Application monitoring and alert response	I	R/A	C	C
Infrastructure monitoring and patching	I	C	–	R/A
Integration retries and reconciliation follow-up	C (Finance)	R/A	C	–
Defect fixes and releases	A (approve)	R	R	C
Database backups and restore	I	R (verify)	C	R/A (run)
DR invocation and tests	A	R	C	R
Security patches (application)	A (approve)	R	R	I
Security patches (OS, database packages)	A (approve)	C	–	R
Monthly service report	I	R/A	C	C

Table 3: RACI (R responsible, A accountable, C consulted, I informed)

3. Support Hours and Service Levels

3.1 Support hours

Support follows the Insurans Islam TAIB business-hours schedule for Family Takaful (COM-14). P1 incidents are covered 24 hours a day, 7 days a week, including weekends and public holidays.

Coverage	Hours
IIFT business hours	[As published in the 'Insurans Islam TAIB Business Hours (Family Takaful)' schedule, e.g. Monday to Thursday and Saturday, 08:00 to 17:00 Brunei time, excluding Friday, Sunday and public holidays]
P1 critical incidents	24 x 7 through the hotline and on-call engineer
Planned maintenance windows	[Agreed with IIFT, e.g. Sunday 08:00 to 12:00], announced 5 business days ahead

Table 4: Support hours

3.2 Severity definitions and SLA

Priority	Definition	Response	Restore / resolve	Coverage
P1 Critical	Production down, or a critical function (sign-in, quotation, issuance, payment verification, EOD) unavailable for all users; data integrity or security breach	30 minutes	4 hours (restore or workaround)	24 x 7
P2 High	Major function impaired for many users with no reasonable workaround	2 hours	1 business day	IIFT business hours
P3 Medium	Function impaired with a workaround; few users affected	4 business hours	3 business days	IIFT business hours
P4 Low	Cosmetic issue, question or minor defect	1 business day	Next scheduled release	IIFT business hours

Table 5: Incident service levels (MNT-05 to MNT-07, COM-13)

- Response: an engineer has acknowledged the incident and started work, measured from logging (or from the call for P1).
- Restore: service or function available again, possibly with a workaround; the permanent fix follows under problem management.
- Priority is set by the helpdesk from impact and urgency and can be changed by agreement; the SLA clock follows the agreed priority.
- The clock pauses while waiting for IIFT information or for infrastructure outside iorta's responsibility; pauses are recorded on the ticket.
- Availability target: 99.5% per month overall and 99.9% within IIFT business hours, excluding approved maintenance windows.
- The Issues module's own SLA timers (Issue SLA parameters sla.*) track user-reported issues inside the application; they are configured to match this table at go-live.

4. Incident Management

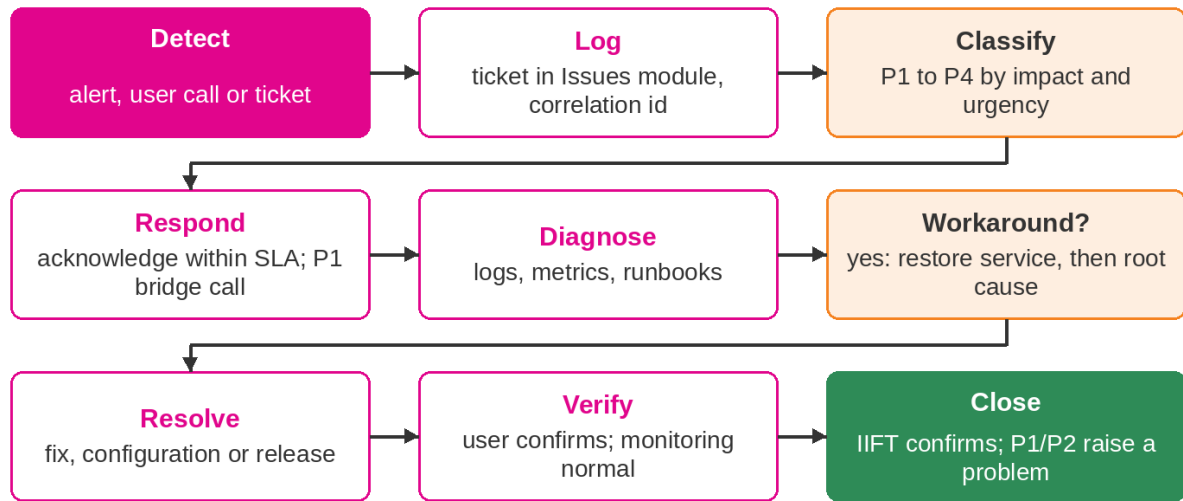


Figure 2: Incident process

Step	What happens	Who
Detect	Alert, user call, e-mail or Issues-module ticket	Monitoring, users
Log	Ticket with symptom, time, user, correlation id, screenshots	L1
Classify	Priority P1 to P4 from the definitions; category	L1
Respond	Acknowledge within SLA; for P1 open a bridge call and notify the escalation contacts	L2
Diagnose	Logs by correlation id, metrics, integration monitor, audit trail, data	L2, L3
Restore	Workaround or fix; runbook where one exists	L2, L3, Infra
Verify	User confirms; monitoring back to normal	L1, L2
Close	IIFT confirms closure; P1 and P2 open a problem record	L1

Table 6: Incident steps (MNT-02)

4.1 P1 procedure

1. Call the on-call engineer; log the ticket; the engineer acknowledges within 30 minutes.
2. Open a bridge call with the IIFT application owner and, if needed, IITH infrastructure.
3. Send a first update to the IIFT contact list within 30 minutes, then every 30 minutes until service is restored: impact, actions, next update time.
4. Restore service by the fastest safe route (restart, rollback, failover, workaround). Record every action with its time on the ticket.
5. Confirm restoration with users; keep monitoring for at least one hour.
6. Issue a short incident summary within 1 business day and a root-cause report within 5 business days.

5. Problem Management

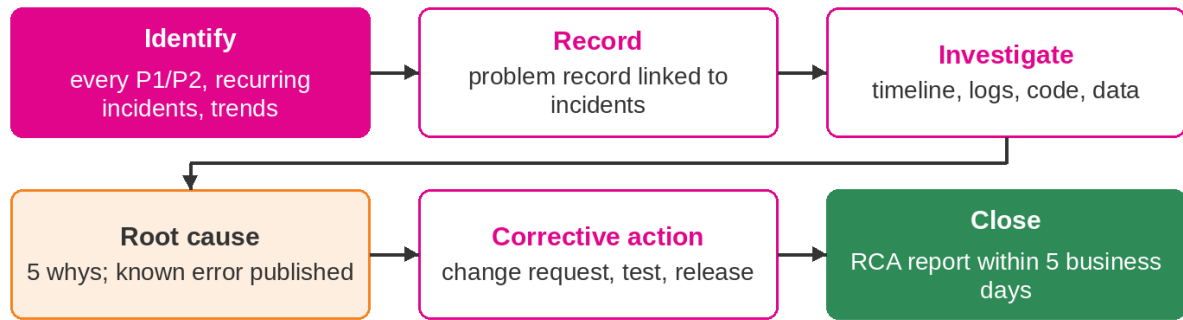


Figure 3: Problem process

A problem record is opened for every P1 and P2, for recurring incidents (three or more with the same symptom in a month) and for trends seen in monitoring (MNT-03). The root-cause report contains: summary and impact; timeline; root cause; why it was not detected earlier; corrective actions with owner and date; preventive actions. Known errors with their workaround are published to the helpdesk until the fix is released.

6. Change Management

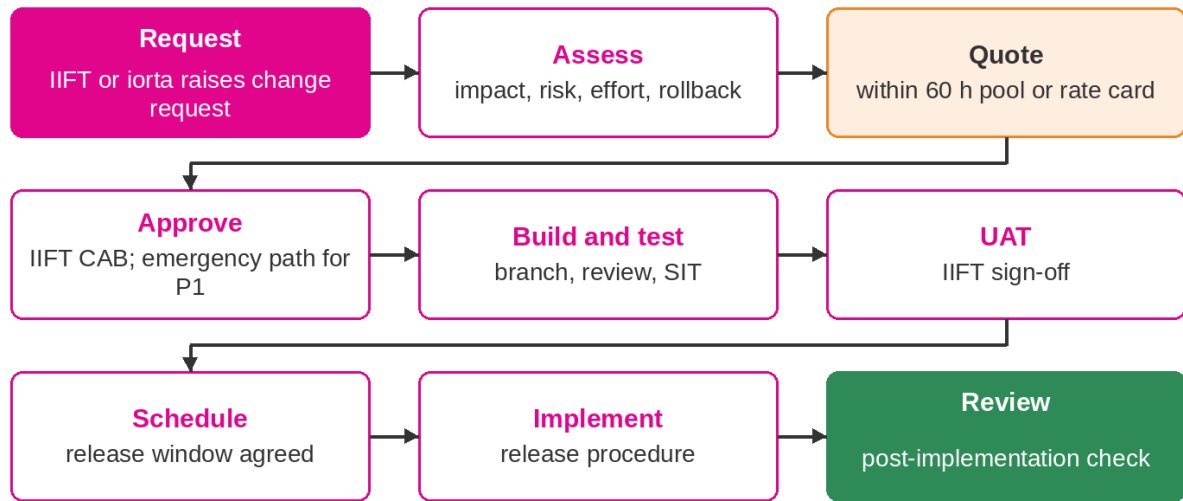


Figure 4: Change process

Type	Examples	Approval	Lead time
Standard	Business parameter within range, master data code, user and role administration, report schedule	Pre-approved; done by IIFT administrators in the back-office; audited	None
Normal	Release, product rate change, workflow change, infrastructure change, integration change	IIFT change approval (CAB) after impact assessment	5 business days
Emergency	Fix for a P1/P2, urgent security patch	IIFT application owner (retrospective CAB review)	As needed

Table 7: Change types

Minor enhancements are delivered from the 60-hour annual pool; larger changes follow the change request process with impact assessment, quotation at the rate card and approval (MNT-23, MNT-24). Data corrections in production are changes: they are scripted, reviewed, run in a transaction, and recorded in the audit trail or the change ticket.

7. Release Management

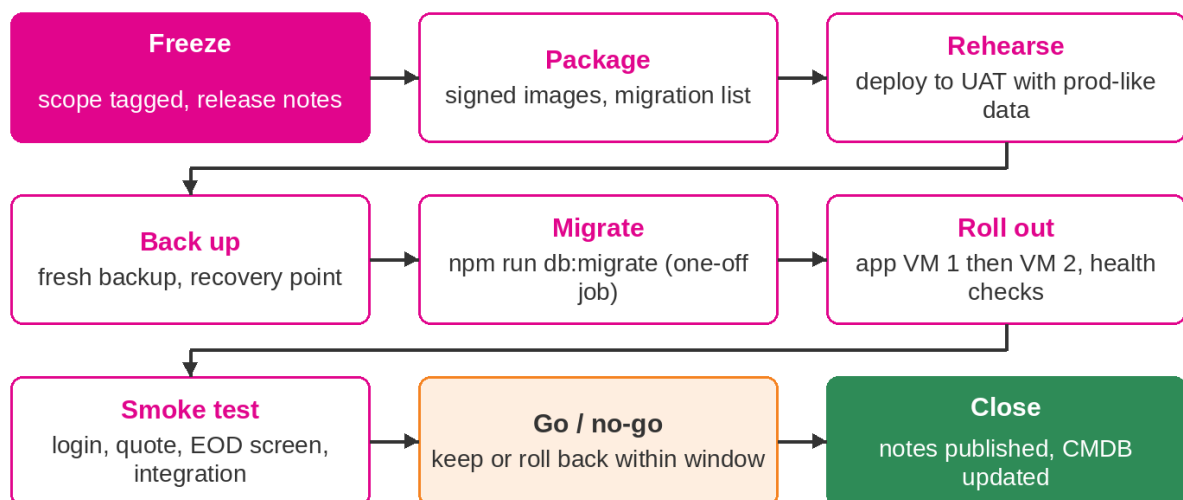


Figure 5: Release process

Release type	Content	Cadence
Emergency fix	P1/P2 defect or urgent security patch	As needed
Maintenance release	Defect fixes, dependency and image patches, minor enhancements	Monthly
Feature release	Change requests	Quarterly or as agreed
Platform upgrade	Node.js, PostgreSQL, framework and SalesVerse 2.0 versions	Typically yearly

Table 8: Release types (MNT-21, MNT-22)

Every release passes the CI pipeline, is deployed to UAT with the same images that will go to production, and is approved by IIFT before it is deployed in an agreed window. Release notes list changes, migrations, configuration changes, risks and the rollback plan. The deployment itself follows runbook R2; rollback follows R3.

8. Escalation Matrix

Names and numbers are completed at mobilisation and checked quarterly.

Level	iorta TechNXT role	Name	Contact	Escalate when
1	Support engineer (on call)	[Name]	[Mobile, e-mail]	On logging; P1 by telephone immediately
2	Support lead	[Name]	[Mobile, e-mail]	P1 not restored in 1 hour; P2 not responded in 2 hours
3	Engineering lead	[Name]	[Mobile, e-mail]	P1 not restored in 2 hours; P2 not resolved in 1 business day
4	Account / project director	[Name]	[Mobile, e-mail]	P1 not restored in 4 hours; repeated SLA breach

Table 9: iorta escalation (COM-15)

Level	IIFT / IITH role	Name	Contact	Involved for
1	IIFT helpdesk	[Name]	[Phone, e-mail]	First contact for users
2	IIFT IT application owner	[Name]	[Phone, e-mail]	P1/P2 decisions, change approval
3	IITH infrastructure on-call	[Name]	[Phone, e-mail]	Server, network, database host, DR
4	IIFT Head of IT / business owner	[Name]	[Phone, e-mail]	Business impact, external communication

Table 10: IIFT and IITH contacts

9. Monitoring and Alerting

9.1 Health endpoints and metrics

Endpoint	Returns	Used by
GET /health/live	200 {status: ok} while the process runs	Docker, load balancer
GET /health/ready	200 {status: ok, database: up}; 503 NOT_READY when PostgreSQL is unreachable	Docker HEALTHCHECK every 30 s, load balancer
GET /metrics	Prometheus text format; process and Node.js metrics prefixed iift_api_; requires 'Authorization: Bearer <METRICS_TOKEN>' when the token is set	Prometheus

Table 11: Health and metrics endpoints

The endpoints are served by the API on port 3000 outside the /api/v1 prefix and are not exposed through nginx. To check from the VM:

```
docker compose ps          # STATUS shows (healthy) for api and web
docker compose exec api node -e "fetch('http://127.0.0.1:3000/health/ready').then(async r =>
console.log(r.status, await r.text()))"
```

9.2 Logs

The API writes JSON lines to standard output (read with docker compose logs api, or in the central log platform). Each HTTP request line carries req.id, the correlation id that is also returned to the browser in X-Request-Id and shown to users as the error reference. Cookies, authorization, CSRF and set-cookie headers are redacted. Example:

```
{"level":30,"time":1791014400123,"req":{"id":"6f1c2a9e-0d1b-4f6e-9a55-3b7e2c1d4a10","method":"POST",
"url":"/api/v1/portal/policies/.../submit"},"res":{"statusCode":422},"responseTime":184,
"msg":"request completed"}
```

```
docker compose logs --since 2h api | grep 6f1c2a9e-0d1b-4f6e-9a55-3b7e2c1d4a10
```

Business events for the same request are in audit_log.correlation_id; integration messages in outbox_message.correlation_id.

9.3 Alerts

Alert rules are configured in Prometheus Alertmanager (or the IITH equivalent) during implementation; the application itself e-mails dead-letters, SLA breaches, AML review requests and agency blocks.

Alert	Condition	Priority	Recipient	Runbook
API not ready	/health/ready fails on any instance for 2 minutes	P1 if all instances, else P2	L2 on call	R1, check database
High error rate	HTTP 5xx above 2% for 5 minutes (nginx logs)	P2	L2	Logs by correlation id
Slow responses	p95 latency above 2 s for 10 minutes	P3	L2	Metrics, slow queries
Event-loop lag	iift_api_nodejs_eventloop_lag_seconds above 0.5 for 5 minutes	P3	L2	Metrics
Memory or disk	Memory above 85% or disk above 80%	P3	Infra, L2	Capacity
Replication lag	Standby more than 5 minutes behind	P2	Infra, L2	Section 11
Backup missing	No successful database backup in 26 hours	P2	Infra	Section 11

Alert	Condition	Priority	Recipient	Runbook
EOD failed	eod_run FAILED, or no COMPLETED run for the previous day by 01:00	P2	L2, Finance	R6
Integration dead-letter	Any outbox_message in DEAD (application also e-mails integration support)	P2	L2	R7
Reconciliation mismatch	reconciliation_run status MISMATCH	P3	Finance, L2	R7
Issue SLA breach	Application e-mails holders of bo.issues.manage when an issue misses a target	Per issue	Support desk	Issues module
Certificate expiry	TLS certificate expires within 30 days	P3	Infra	Renew

Table 12: Alerts

9.4 Daily health check

- Grafana overview: all instances ready, error rate and latency normal overnight.
- Back-office > End of day: yesterday's run COMPLETED, totals plausible, files present.
- Back-office > Integration: no DEAD messages; pending and retrying counts near zero; reconciliation MATCHED.
- Backup report: last full backup and WAL archiving successful; replication lag normal.
- Issues module: new P1/P2 tickets, SLA breaches.
- Back-office > Agencies: agencies newly blocked overnight (expected after the 01:00 job) communicated to Distribution.

10. Operational Runbooks

Each runbook lists who may run it, the steps and how to verify the result. Run every runbook once in UAT during knowledge transfer. Production commands are run on the VMs through the bastion, under a change ticket unless stated otherwise.

10.1 R1 Start and stop the service

Planned stop for maintenance, or restart after an infrastructure event. On production run the steps on one application VM at a time so the service stays available.

Needs: L2 or IITH infrastructure; change ticket for production.

#	Action
1	Announce the window if users will be affected.
2	Stop: docker compose --env-file .env stop web api (ClamAV can stay up).
3	Start: docker compose --env-file .env up -d (starts or recreates containers as needed).
4	Wait until docker compose ps shows api and web as healthy (start period 30 s).
5	Repeat on the second application VM.
6	Database VMs: systemctl stop start postgresql@16-main (stop the standby last and start the primary first).

Verify: health/ready returns 200 on both VMs; sign in to the back-office; Integration screen shows pending messages draining.

- Stopping the API mid-job is safe: the advisory lock is released and the job runs again at its next schedule; an interrupted EOD can be re-run (R6).

10.2 R2 Deploy a release with database migrations

Deploys a release that has passed UAT. Migrations are applied once, before the new containers start; they are backward compatible (expand-and-contract), so old and new containers can run together during the rolling update.

Needs: L2 with IIFT change approval.

```
cd /opt/salesverse/deploy
docker compose --env-file .env run --rm migrate
docker compose --env-file .env up -d api web
docker compose ps
```

#	Action
1	Confirm IIFT approval, release notes and the rollback criteria.
2	Take a backup: pgbackrest --stanza=iift --type=incr backup on the database primary; note the time.
3	Load the release images (docker compose pull from the IITH registry, or docker load from the release package) and set RELEASE in deploy/.env; the production compose override (delivered during implementation) references the images by this tag.
4	Apply migrations and reference data once: docker compose --env-file .env run --rm migrate. Equivalent from a source checkout: cd apps/api && npm run db:migrate (with DATABASE_URL set to the migration role).
5	Check the output ends with 'All migrations have been successfully applied' (or 'No pending migrations').
6	VM 1: docker compose --env-file .env up -d api web; wait for healthy; run smoke tests.
7	VM 2: same command; wait for healthy.
8	Smoke tests: sign in to portal and back-office, open a policy, calculate a quotation, open End of day and Integration screens, download a document.
9	Record the release, time and result on the change ticket; publish release notes.

Verify: The version in the release notes matches the running images (docker compose images); no new errors in logs for 30 minutes.

10.3 R3 Roll back a release

Returns to the previous release when the go/no-go check fails or a serious defect appears after release.

Needs: L2 with the IIFT application owner.

#	Action
1	Decide with the IIFT application owner using the rollback criteria in the release notes.
2	Set RELEASE back to the previous tag in deploy/.env and run docker compose --env-file .env up -d api web on each VM in turn.
3	Do not reverse migrations: the previous release runs on the expanded schema.
4	If a migration failed part-way, Prisma marks it failed: fix the cause, then run <code>npx prisma migrate resolve --rolled-back <migration></code> before re-applying, or restore (R5) if data was changed.
5	Restore the database (R5) only if the release corrupted data; this needs IIFT approval because transactions after the restore point are lost.

Verify: Smoke tests from R2 pass on the previous version.

10.4 R4 Rotate secrets and keys

Scheduled rotation (yearly or on staff change) or emergency rotation after suspected exposure. Secrets are held in the vault and injected as environment variables; containers read them at start.

Needs: L2 with IITH security; emergency rotation can start before CAB approval.

#	Action
1	SESSION_SECRET: generate (openssl rand -hex 32), update the vault, restart api on both VMs; every user must sign in again, so do it in a quiet period.
2	INBOUND_API_KEY_SHA256: generate a key (openssl rand -base64 32), compute its hash (printf '%s' "\$KEY" sha256sum), agree a cut-over time with IITH, update the hash and restart api, then give the new key to the Core and FIN teams. Only one key is valid at a time.
3	Outbound API keys, SMTP and LDAP passwords: obtain the new value from the provider, update the vault, restart api, check the Integration screen and send a test e-mail.
4	Database passwords: ALTER ROLE ... PASSWORD on the primary, update DATABASE_URL in the vault, restart api VM by VM.
5	METRICS_TOKEN: update the vault and the Prometheus scrape configuration together.
6	FIELD_ENCRYPTION_KEY, FIELD_HASH_KEY, DOCUMENT_ENCRYPTION_KEY: never change by editing the variable; existing data would become unreadable. Rotation uses the re-encryption tool delivered during implementation, under a dedicated change with a fresh backup.

Verify: Sign-in works; integration calls succeed; /metrics scraped; audit trail shows normal activity.

10.5 R5 Restore from backup

Recovers the database to a point in time after data loss or corruption, or rebuilds a server.

Needs: IITH infrastructure runs the restore; L2 verifies; IIFT approves.

#	Action
1	Agree the target time with IIFT (the last good moment) and record it.
2	Stop the API on both VMs (R1) so nothing writes during the restore.
3	On the database host: <code>systemctl stop postgresql@16-main</code> .
4	Restore: <code>pgbackrest --stanza=iift --delta --type=time "--target=2026-11-05 10:42:00+08" --target-action=promote restore</code> .

#	Action
5	Start PostgreSQL and wait for recovery to finish (pg_is_in_recovery() returns false).
6	Re-create the standby from the new primary (pgbackrest restore --type=standby on the standby host).
7	Documents: restore the document store to the same point from the document backup if files were lost.
8	Start the API (R1) and reconcile: counts of policies, receipts and payments for the affected days; re-run EOD for affected dates (R6).
9	Outbox messages created before the target but delivered after it are sent again; receivers ignore them by Idempotency-Key. Check the Integration screen for DEAD messages.

Verify: Application readiness, reconciliation of counts with IIFT, EOD and reconciliation MATCHED.

- For DEV, SIT and UAT (compose database): docker compose exec db pg_dump -U iift -Fc iift > backup.dump and pg_restore --clean -d iift backup.dump.

10.6 R6 Re-run end-of-day

Runs EOD again for a business date after a failure, after late corrections, or after a restore.

Needs: Finance officer or L2 with bo.eod.run.

#	Action
1	Back-office > End of day: check the run for the date (status, error message).
2	Fix the cause shown in the error message or logs (search 'EOD' in the API log for that night).
3	Choose Run, enter the business date (YYYY-MM-DD) and confirm. API: POST /api/v1/backoffice/eod with {"businessDate": "2026-11-04"}.
4	The run refuses future dates, and refuses a date whose run started less than 30 minutes ago and is still RUNNING.
5	The run for the date is updated in place with new totals, report and FIN file; reconciliation runs again.
6	Tell Finance that a fresh EOD_POSTING was sent for the date.

Verify: Status COMPLETED; totals match the policy and collection reports for the date; reconciliation MATCHED or explained.

10.7 R7 Retry integration messages

Clears dead-letter messages after the cause has been fixed (receiver down, credentials expired, data rejected).

Needs: L2 or Finance with bo.integration.manage.

```
-- List dead-letter messages (read-only)
SELECT id, system, operation, attempts, last_error, created_at
FROM outbox_message WHERE status = 'DEAD' ORDER BY created_at;
```

#	Action
1	Back-office > Integration: filter status DEAD; open the message; read last_error and the integration log entries.
2	Fix the cause first: receiver available, credentials valid, or the data corrected in the source record.
3	Select Retry (POST /api/v1/backoffice/integration/outbox/{id}/retry). The message returns to PENDING with attempts reset and is sent within 20 seconds.
4	For many messages after an outage, retry in creation order so events for one record stay in order.
5	A message rejected with HTTP 4xx will fail again unless its payload is valid for the receiver; raise a problem record with the receiving team.

Verify: Message status SENT; integration log shows success; the receiving system confirms.

10.8 R8 Unlock a user or reset a password

A user is locked after repeated failed sign-ins (5 attempts, 30 minutes by default) or has forgotten the password.

Needs: IIFT administrator (L1) with bo.users.manage; an administrator cannot reset their own password this way.

#	Action
1	Verify the caller's identity with the IIFT procedure (call-back to the registered number).
2	Back-office > Users: find the user. Status LOCKED: choose Unlock (POST /api/v1/backoffice/users/{id}/unlock). The lock also clears itself when the period ends.
3	Forgotten password: choose Reset password. A temporary password is shown once to the administrator; give it to the user through a separate channel. The user must change it at sign-in, and all the user's sessions are ended.
4	DISABLED users are re-activated, not unlocked. Directory (AD) users are unlocked and reset in Active Directory, not in the application.
5	Repeated lockouts for one account: check the audit trail (LOGIN_FAILED, ACCOUNT_LOCKED) for signs of an attack and inform IIFT IT security.

Verify: The user signs in; audit trail shows USER_UNLOCKED or USER_PASSWORD_RESET.

10.9 R9 Lift an agency issuance block

The 01:00 job blocks an agency's new business when an issued policy is unpaid past its due date, and lifts the block automatically once nothing is overdue. A manual lift is for payments made outside the portal or agreed exceptions.

Needs: Operations or Finance with bo.agencies.manage, with IIFT approval.

#	Action
1	Back-office > Agencies: open the agency; read the block reason (number of overdue policies, amount).
2	Preferred: have the agency submit the payment and Finance verify it; the block lifts at the next 01:00 run.
3	If a manual lift is approved by IIFT, choose Lift block and enter the reason and approval reference (POST /api/v1/backoffice/agencies/{id}/lift-block).
4	Make sure the overdue policies are paid before 01:00; otherwise the job re-applies the block.

Verify: Agency shows issuance not blocked; agents can submit; audit trail shows AGENCY_BLOCK_LIFTED with the reason.

10.10 R10 Replace an AML watch-list

Loads a new version of a sanctions, PEP or internal list from Compliance.

Needs: Compliance officer with bo.aml.review.

#	Action
1	Prepare a UTF-8 CSV whose first line is exactly: list_name,full_name,id_number,country,reference. list_name and full_name are mandatory; up to 20,000 entries per file.
2	Back-office > AML > Watch-list > Import; choose the file and tick 'Replace list' (replaceList=true); entries of the lists named in the file are deactivated and the file's entries become the active list. Without the option, entries are added.
3	Import runs in one transaction: a format error rejects the whole file with the line number.
4	Spot-check: search the watch-list for a few new names.
5	Screening is applied to new registrations and name changes from now on; re-screening of existing agents and participants against a new list is requested from L2 as a service request.

Verify: Import result shows the expected count; audit trail shows WATCHLIST_IMPORTED with the list names and count.

10.11 R11 Apply a product rate change

Changes rates, plans, limits or questionnaire for a product, for example when IIFT actuarial issues new rates.

Needs: System administrator with bo.products.manage, with IIFT actuarial sign-off.

#	Action
1	Receive the signed rate change from IIFT actuarial with its effective date.
2	In UAT: Back-office > Products: edit the product configuration; save. The rating engine validates the configuration and names the exact field if a value is invalid.
3	Quote test cases agreed with actuarial in UAT and compare with their expected contributions; obtain sign-off.
4	In production, on the effective date and after that day's EOD: apply the same change (second person checks the values against the signed sheet).
5	From then on new quotations use the new rates. Drafts saved earlier are re-rated at submission, so agents see the new contribution when they submit; inform Distribution beforehand.

Verify: Audit trail shows PRODUCT_UPDATED with before and after values; a test quotation in production gives the expected contribution and is then discarded.

- Product changes are not routed through maker-checker in the application; the two-person check above is the control until an approval type for products is added.

10.12 R12 Investigate an error reported by a user

A user quotes the reference shown on an error message.

Needs: L1 for business-rule messages; L2 for logs and database.

```
SELECT occurred_at, actor_name, action, entity_type, entity_id
FROM audit_log WHERE correlation_id = '6f1c2a9e-0d1b-4f6e-9a55-3b7e2c1d4a10';
```

#	Action
1	Search the logs for the reference (correlation id) over the time of the error.
2	Read the error entry (stack trace for 500 errors) and the request line (URL, status, user).
3	Check audit_log and outbox_message for the same correlation_id to see what was committed.
4	4xx errors with a code (for example AGENCY_BLOCKED, SUBMISSION_INCOMPLETE) are business rules: explain the message and details to the user.
5	500 errors: open an incident with the stack trace and steps to reproduce.

11. Backup and Disaster Recovery

11.1 Backup schedule

What	How	When	Retention
Database full	pgBackRest full backup to the backup repository	Daily 02:00	35 days
Database WAL	Continuous archiving (archive_timeout 300 s)	Continuous	35 days
Database monthly	Copy of the first full backup of the month	Monthly	12 months
Document store	Incremental file backup; weekly full	Daily 03:00	35 days; monthly 12 months
Configuration	deploy files, compose overrides, vault export (encrypted)	On change	All versions
Off-site	Copy of backups to the DR site	Daily	As above

Table 13: Backups (NFR-17)

11.2 Targets

RPO 15 minutes or better (the local standby is near-real-time; archived WAL bounds loss to 5 minutes if both database nodes are lost); RTO 4 hours for loss of the primary site. Loss of one application VM has no outage; loss of the database primary is recovered by promoting the local standby within 30 minutes.

11.3 Database failover to the local standby

Promotion procedure

#	Action
1	Confirm the primary is down and will not return quickly (IITH infrastructure).
2	Make sure the old primary cannot start again (stop the service or isolate the VM) to avoid two primaries.
3	On the standby: <code>pg_ctlcluster 16 main promote</code> (or <code>SELECT pg_promote();</code>).
4	Move the database VIP or DNS name to the promoted server; the API reconnects automatically (readiness turns green).
5	Rebuild the old primary as the new standby when it is repaired.

11.4 DR invocation

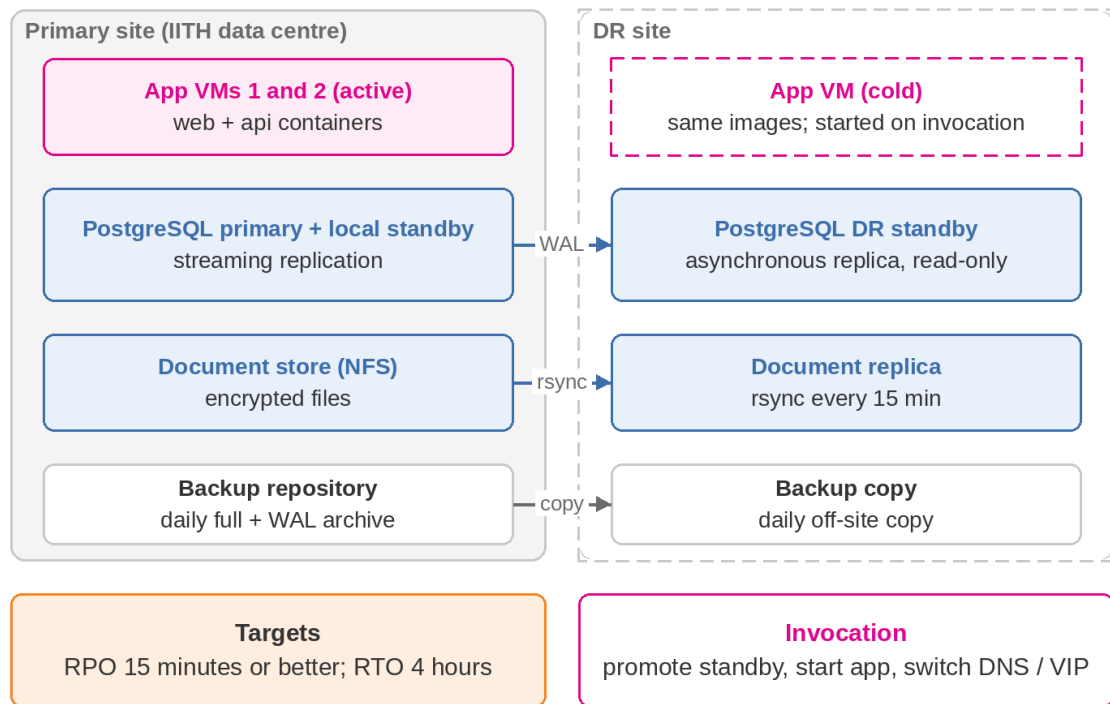


Figure 6: DR topology

Invocation procedure

#	Action
1	Declare the disaster with the IIFT application owner and IITH infrastructure; record the time.
2	Promote the DR database replica; note the last replayed transaction time (data after it is lost).
3	Mount the document replica at /data/documents on the DR application VM.
4	Start the containers with the DR configuration: <code>docker compose --env-file .env.dr up -d</code> .
5	Switch DNS or the external load balancer to the DR site; confirm TLS certificates.
6	Run the R2 smoke tests; re-run EOD for the last business day if it did not complete (R6).
7	Inform users and IITH system owners; monitor closely.
8	Plan fail-back after the primary site is restored: rebuild replication in reverse, then switch in a maintenance window.

11.5 Test schedule

Test	Frequency	Scope	Evidence
Restore test	Quarterly	Restore the latest backup to a scratch server; reconcile counts and amounts	Restore record (MNT-19)
Local failover	Twice a year, in a maintenance window	Promote the standby, run the service, rebuild	Change record
DR site test	Yearly	Full invocation at the DR site with IIFT users testing key functions; fail-back	DR test report (NFR-19, MNT-20)
Document restore	Twice a year	Restore a sample of files and open them in the application	Restore record

Table 14: Backup and DR tests

12. Configuration Reference

Every environment variable read by the API (apps/api/src/config/app-config.ts), as of this release. The API validates them at start-up and refuses to start with a missing or invalid value; in production it also refuses insecure combinations. Secrets come from the vault, never from files in the repository.

Variable	Group	Required / default	Purpose	Example
NODE_ENV	Runtime	Default development	production enables the production safety checks and secure defaults.	production
PORT	Runtime	Default 3000	HTTP port the API listens on inside the container.	3000
TRUST_PROXY_HOPS	Runtime	Default 1	Number of reverse proxies in front of the API, so client IPs in logs and audit are correct.	1
DATABASE_URL	Database	Required	PostgreSQL connection string for the application role; use sslmode=require.	postgresql://iift_app:***@db-vip:5432/iift?sslmode=require
DATABASE_POOL_SIZE	Database	Default 10	Maximum connections per API instance for business queries (the session store uses a separate pool of 5).	10
CORS_ORIGINS	HTTP	Optional	Comma-separated origins allowed for cross-origin calls. Leave empty when the SPA and API share one origin behind the proxy.	(empty)
PUBLIC_BASE_URL	HTTP	Default http://localhost:5173	External base URL used in links sent by e-mail (e-signature links).	https://portal.iift.com.bn
API_DOCS_ENABLED	HTTP	Default false in production	Serves Swagger UI at /api/docs. Must be false in production.	false
SESSION_SECRET	Security	Required	Secret that signs the session cookie; at least 32 characters.	(64 random chars)
SESSION_COOKIE_NAME	Security	Default iift.sid	Name of the session cookie.	iift.sid
SESSION_COOKIE_SECURE	Security	Default true in production	Sends the cookie over HTTPS only. Must be true in production.	true
FIELD_ENCRYPTION_KEY	Security	Required	Base64 256-bit key for AES-256-GCM encryption of IC/passport numbers.	(base64, 32 bytes)
FIELD_HASH_KEY	Security	Required	Base64 256-bit key for the HMAC-SHA256 blind index of identification numbers.	(base64, 32 bytes)
DOCUMENT_ENCRYPTION_KEY	Security	Required	Base64 256-bit key for AES-256-GCM encryption of stored documents.	(base64, 32 bytes)
DOCUMENT_STORAGE_PATH	Documents	Default ./storage/documents	Directory of the encrypted document store (NFS mount on-premise, EFS in the cloud).	/data/documents
MAX_UPLOAD_MB	Documents	Default 10	Largest accepted upload in MB (the HTTP layer also refuses bodies over 25 MB).	10
CLAMAV_HOST	Documents	Optional	clamd host for malware scanning of uploads; scanning is skipped when empty.	clamav
CLAMAV_PORT	Documents	Default 3310	clamd TCP port.	3310
JOBS_ENABLED	Jobs	Default true	Runs scheduled jobs in this instance. Locks prevent double runs, so it can stay true on every replica.	true
JOBS_TIMEZONE	Jobs	Default Asia/Brunei	Time zone of EOD_CRON.	Asia/Brunei
EOD_CRON	Jobs	Default 0 30 23 * * *	Six-field cron expression (with seconds) for end-of-day processing.	0 30 23 * * *
INTEGRATION_MODE	Integration	Default simulated	simulated records messages without calling external systems; live calls the configured endpoints.	live

Variable	Group	Required / default	Purpose	Example
INBOUND_API_KEY_SHA256	Integration	Required in production with live mode	Hex SHA-256 of the API key that Core and FIN present to /api/v1/integration. The key itself is not stored.	(64 hex chars)
CORE_API_BASE_URL	Integration	Required in production with live mode	Base URL of the core system API.	https://core.iith.local/api
CORE_API_API_KEY	Integration	Optional (set together)	API key sent to the core system (x-api-key).	(secret)
CORE_API_TIMEOUT_MS	Integration	Default 15000	Timeout of a core system call.	15000
FINANCE_API_BASE_URL	Integration	Required in production with live mode	Base URL of the financial system (FIN) API.	https://fin.iith.local/api
FINANCE_API_API_KEY	Integration	Optional (set together)	API key sent to FIN.	(secret)
FINANCE_API_TIMEOUT_MS	Integration	Default 15000	Timeout of a FIN call.	15000
AML_API_BASE_URL	Integration	Optional (set together)	Base URL of the external AML screening service (optional).	https://aml.provider.example/v1
AML_API_API_KEY	Integration	Optional (set together)	API key of the AML service.	(secret)
AML_API_TIMEOUT_MS	Integration	Default 15000	Timeout of an AML call.	15000
SMS_API_BASE_URL	Notifications	Optional (set together)	Base URL of the SMS gateway HTTP API.	https://sms.provider.example/v1
SMS_API_API_KEY	Notifications	Optional (set together)	Bearer token of the SMS gateway.	(secret)
SMS_API_TIMEOUT_MS	Notifications	Default 15000	Timeout of an SMS call.	15000
SMS_SENDER_ID	Notifications	Default IIFT	Sender name shown on SMS messages.	IIFT
SMTP_HOST	Notifications	Required in production with live mode	SMTP relay host; e-mail is recorded but not sent when empty.	smtp.iith.local
SMTP_PORT	Notifications	Default 587	SMTP port.	587
SMTP_SECURE	Notifications	Default false	true for implicit TLS (465); false uses STARTTLS, which is then required.	false
SMTP_USER	Notifications	Optional	SMTP user name, if the relay requires authentication.	portal-mailer
SMTP_PASSWORD	Notifications	Optional	SMTP password.	(secret)
SMTP_FROM	Notifications	Required when SMTP_HOST is set	Sender address (required when SMTP_HOST is set).	no-reply@iift.com.bn
LDAP_URL	Directory	Optional	Directory URL for back-office sign-in; use ldaps://.	ldaps://ad.iith.local:636
LDAP_BIND_DN	Directory	Required when LDAP_URL is set	Service account used to look up users.	CN=svc-portal,OU=Service,DC=iith,DC=local
LDAP_BIND_PASSWORD	Directory	Required when LDAP_URL is set	Service account password.	(secret)
LDAP_BASE_DN	Directory	Required when LDAP_URL is set	Search base for users.	OU=Staff,DC=iith,DC=local
LDAP_USER_FILTER	Directory	Default (sAMAccountName={{username}})	Search filter; {{username}} is replaced with the escaped user name.	(sAMAccountName={{username}})
METRICS_TOKEN	Monitoring	Optional	Bearer token required by /metrics when set.	(secret)
LOGIN_RATE_LIMIT_PER_MINUTE	Security	Optional	Sign-in attempts allowed per client IP per minute and API instance.	10
LOG_LEVEL	Monitoring	Optional	pino log level; defaults to info in production and debug otherwise.	info
SEED_ADMIN_PASSWORD	Set-up	Optional	Temporary password of the first administrator created by npm run db:seed (12+ characters, changed at first sign-in).	(one-off secret)
SEED_ADMIN_EMAIL	Set-up	Optional	E-mail of the first administrator.	it.admin@iift.com.bn

Variable	Group	Required / default	Purpose	Example
DEMO_PASSWORD	Set-up	Optional	Password of demonstration users loaded by npm run db:seed:demo; refused in production.	(non-production only)

Table 15: Environment variables

12.1 Business parameters

Maintained in Back-office > Parameters by holders of bo.config.manage; each change is audited and takes effect within a minute.

Key	Category	Default	Range	Meaning
security.password.min_length	Security	12	8 to 64	Minimum password length
security.password.require_upper	Security	true	–	Password must contain an upper-case letter
security.password.require_lower	Security	true	–	Password must contain a lower-case letter
security.password.require_digit	Security	true	–	Password must contain a digit
security.password.require_symbol	Security	true	–	Password must contain a symbol
security.password.history_count	Security	5	0 to 24	Number of previous passwords that cannot be reused
security.password.expiry_days	Security	90	0 to 365	Days before a password must be changed (0 = never)
security.lockout.max_attempts	Security	5	3 to 20	Failed login attempts before the account is locked
security.lockout.minutes	Security	30	1 to 1440	Lock duration in minutes (administrator can unlock earlier)
security.session.idle_minutes	Security	15	5 to 120	Session idle timeout in minutes
security.session.absolute_hours	Security	8	1 to 24	Maximum session lifetime in hours
security.session.single_active	Security	true	–	Signing in ends the user's other sessions
billing.payment_grace_days	Billing	7	1 to 60	Days after issuance within which contribution must be submitted before the agency is blocked
policy.quotation_validity_days	Policy	30	1 to 180	Days a draft quotation remains valid
policy.renewal_notice_days	Policy	45	7 to 120	Days before expiry that a policy is listed as due for renewal
policy.require_participant_signature	Policy	true	–	Participant signature is mandatory before submission
policy.esign_link_hours	Policy	72	1 to 336	Validity of e-signature links sent by email (hours)
aml.match_threshold	Compliance	85	50 to 100	Name-match score (0-100) at or above which a screening is flagged for review
commission.default_rate	Commission	0.10	0 to 1	Default commission / referral fee rate when the product does not define one
sla.critical.response_hours	Issue SLA	1	1 to 72	Critical issue response target (hours)
sla.critical.resolution_hours	Issue SLA	4	1 to 168	Critical issue resolution target (hours)
sla.high.response_hours	Issue SLA	2	1 to 72	High issue response target (hours)
sla.high.resolution_hours	Issue SLA	24	1 to 336	High issue resolution target (hours)
sla.medium.response_hours	Issue SLA	8	1 to 168	Medium issue response target (hours)
sla.medium.resolution_hours	Issue SLA	72	1 to 720	Medium issue resolution target (hours)
sla.low.response_hours	Issue SLA	24	1 to 336	Low issue response target (hours)
sla.low.resolution_hours	Issue SLA	168	1 to 2160	Low issue resolution target (hours)
integration.max_attempts	Integration	6	1 to 20	Delivery attempts before an integration message is moved to dead-letter

Key	Category	Default	Range	Meaning
notification.max_attempts	Notification	5	1 to 20	Email/SMS delivery attempts before giving up
document.expiry_warning_days	Documents	30	1 to 180	Days before expiry that documents are flagged

Table 16: Business parameters

13. Scheduled Jobs

All jobs run inside the API containers. Each takes a PostgreSQL advisory lock named after the job, so only one instance runs it at a time. JOBS_ENABLED=false switches all jobs off in an instance.

Job	Schedule (Brunei time)	Lock name	Purpose	Source	If it fails
end-of-day	Daily 23:30 (EOD_CRON, JOBS_TIMEZONE)	end-of-day	EOD report, FIN file, EOD_POSTING message, receipt reconciliation	eod/eod.service.ts	Re-run from Back-office > End of day (R6)
policy-expiry	Daily 00:05	policy-expiry	ACTIVE policies past end date become EXPIRED; agent notified	policies/policy.jobs.ts	Runs again at the next schedule; restart not needed
payment-grace-period	Daily 01:00	payment-grace-period	Blocks agencies with overdue issue-then-pay policies; lifts the block when settled	billing/grace-period.service.ts	Runs again at the next schedule; restart not needed
outbox-dispatch	Every 20 seconds	outbox-dispatch	Delivers up to 25 due outbox messages to Core and FIN	integration/outbox.dispatcher.ts	Runs again at the next schedule; restart not needed
notification-dispatch	Every 30 seconds	notification-dispatch	Sends up to 50 pending e-mail and SMS notifications	notifications/notification.dispatcher.ts	Runs again at the next schedule; restart not needed
issue-sla-monitor	Every 5 minutes	issue-sla-monitor	Flags issues past their response or resolution target and alerts support	issues/issues.service.ts	Runs again at the next schedule; restart not needed
scheduled-reports	Every 15 minutes	scheduled-reports	Runs due report schedules and e-mails the files	reports/reports.service.ts	Runs again at the next schedule; restart not needed
session pruning	Every 15 minutes	none (idempotent)	Deletes expired rows from user_session	connect-pg-simple	Runs again at the next schedule; restart not needed

Table 17: Scheduled jobs

14. Knowledge Transfer Plan

Knowledge transfer runs from UAT to hypercare exit and continues each year for new IIFT and IITH staff (MNT-28). Sessions are recorded and the recordings handed over with the materials.

#	Session	Audience	Duration	Materials
1	Solution overview and architecture	IIFT IT, IITH infrastructure	2 h	Solution Architecture, live demonstration
2	Back-office administration: users, roles, workflows, parameters, products, master data	IIFT administrators	3 h	Administrator manual, UAT environment
3	Operations: monitoring, EOD, integration monitor, reconciliation, daily checks	IIFT IT, Finance	3 h	This document, dashboards
4	Runbooks hands-on: start/stop, deploy, rollback, restore, retries	IIFT IT, IITH infrastructure	4 h	UAT environment, runbooks
5	Infrastructure: containers, PostgreSQL replication, backups, DR	IITH infrastructure	3 h	Deployment scripts, DR plan
6	Security operations: keys, secrets, access reviews, audit trail, VAPT findings	IIFT IT security	2 h	Security Assessment Report
7	Code walk-through for developers: structure, conventions, tests, adding features	IIFT/IITH developers	2 × 3 h	Developer onboarding guide, repository
8	Helpdesk: common questions, triage, priority rules, escalation	IIFT helpdesk	2 h	Known-error list, FAQ

Table 18: Knowledge transfer sessions

Completion criteria: each session delivered and attended; IIFT/IITH staff have run runbooks R1, R2, R5, R6, R7 and R8 in UAT unaided; questions log closed.

15. Developer Onboarding Guide

15.1 Repository layout

Path	Contents
apps/api/src/main.ts, app.setup.ts, app.module.ts	Entry point, HTTP pipeline, module list and global guards
apps/api/src/config	AppConfig: typed, validated environment variables
apps/api/src/common	Prisma service and job locks, field crypto, numbering, data scope, permissions, decorators, request context, errors, pagination, dates and money
apps/api/src/modules/<area>	One folder per functional area: controller, service, DTOs, handlers, jobs, unit tests
apps/api/prisma	schema.prisma, migrations, reference data (seed.ts) and demonstration data (seed-demo.ts)
apps/api/test	End-to-end tests against a dedicated *_test database
apps/web/src	routes.tsx, layouts (AppShell, menus), api (client, hooks, types), pages per audience, shared components, theme
deploy	docker-compose.yml and .env.example
tools/security	Repeatable OWASP Top 10 checks
docs/api, docs/technical	OpenAPI description; this document pack and its generators

Table 19: Repository layout

15.2 Local set-up

```
# Node.js 22.12+ and npm 11, PostgreSQL 16 running locally
npm ci
createdb iift # or CREATE DATABASE iift; as postgres
cp apps/api/.env.example apps/api/.env # fill in DATABASE_URL and the secrets:
# SESSION_SECRET: openssl rand -hex 32
# FIELD_ENCRYPTION_KEY, FIELD_HASH_KEY, DOCUMENT_ENCRYPTION_KEY: openssl rand -base64 32
cd apps/api
npm run db:migrate # prisma migrate deploy
SEED_ADMIN_PASSWORD='<temporary password>' npm run db:seed
DEMO_PASSWORD='<demo password>' npm run db:seed:demo # optional, never in production
npm run start:dev # API on :3000, Swagger at /api/docs
cd ../web && npm run dev # UI on :5173, proxies /api to :3000
```

Sign in as admin with the temporary password and change it. With demonstration data, agents (ag-000001 ...), bank officers and staff users (ops.maker, ops.checker, underwriter, finance, compliance, support, manager) use DEMO_PASSWORD.

15.3 Scripts

Package	npm run ...	Command
root	build	npm run build -w apps/api && npm run build -w apps/web
root	lint	npm run lint -w apps/api && npm run lint -w apps/web
root	test	npm run test -w apps/api && npm run test -w apps/web
root	dev:api	npm run start:dev -w apps/api
root	dev:web	npm run dev -w apps/web
apps/api	build	prisma generate && nest build
apps/api	start	nest start
apps/api	start:dev	nest start --watch
apps/api	start:prod	node dist/main.js
apps/api	lint	oxlint src test
apps/api	format	prettier --write "src/*.ts" "test/*.ts"

Package	npm run ...	Command
apps/api	typecheck	tsc --noEmit -p tsconfig.json
apps/api	test	vitest run
apps/api	test:e2e	vitest run --config ./vitest.config.e2e.ts
apps/api	db:generate	prisma generate
apps/api	db:migrate	prisma migrate deploy
apps/api	db:migrate:dev	prisma migrate dev
apps/api	db:seed	node --import @swc-node/register/esm-register prisma/seed.ts
apps/api	db:seed:demo	node --import @swc-node/register/esm-register prisma/seed-demo.ts
apps/web	dev	vite
apps/web	build	tsc -b && vite build
apps/web	preview	vite preview
apps/web	lint	oxlint src
apps/web	typecheck	tsc -b
apps/web	test	vitest run

Table 20: npm scripts

15.4 Coding conventions

- TypeScript strict mode, ES modules with .js import suffixes; Prettier (single quotes, trailing commas, 100 columns) and oxlint must pass; CI checks formatting, lint, types, tests and build.
- Controllers are thin: validation by DTO classes (class-validator), authorisation by decorators (@ForAudience, @RequirePermissions, @Public only where intended), logic in services.
- Every state change that matters is audited with AuditService.record inside the same transaction; anything sent to Core or FIN goes through OutboxService.enqueue in that transaction.
- Business rule failures throw BusinessRuleError with a stable code; missing records use notFound(); stale updates use staleRecord(). Never return stack traces or internal messages to clients.
- Portal queries always apply the data scope (DataScopeService.recordFilter); back-office routes declare permissions.
- Money as Prisma.Decimal through money()/sum(); dates as UTC instants or business dates via businessToday(); reference numbers via NumberingService.
- Database changes only by migration (npx prisma migrate dev --name <change>), reviewed in the pull request, expand-and-contract for anything already in production; update dictionary_text.py so the Data Dictionary build passes.
- Tests: unit tests next to the code (*.spec.ts); end-to-end tests in apps/api/test for new endpoints and permissions.
- British English in user-facing text; Shariah-appropriate terms (participant, contribution, takaful).

15.5 How to

Task	Steps
Add a module	Create apps/api/src/modules/<area> with <area>.module.ts, controller, service and DTOs; add the module to app.module.ts; add permissions to common/security/permissions.ts (code and catalogue entry) and to roles in reference-data/roles.ts; add tests.
Add an endpoint	Add the method to the controller with @Get/@Post..., a DTO for the body or query, @RequirePermissions (and audience on the controller); implement in the service with scope and audit; add an end-to-end test for allowed and denied users; regenerate docs/api/openapi.json.
Add a product	Add the product to prisma/reference-data/products.ts with code, rating engine (FINANCING or FIXED_PLAN), config, required documents and questionnaire; run npm run db:seed (adds missing products only) or create it in production through a scripted change; if the product needs a new rating model, add an engine in modules/products/rating and register it in rating-engines.ts with unit tests.
Add a report	Add a ReportDefinition (code, name, audiences, filters, columns, run) to modules/reports/report-definitions.ts; use the data scope in run(); export, preview and scheduling work without further code; add a unit test.

Task	Steps
Add an approval type	Add the value to enum ApprovalType in schema.prisma and create a migration; add a workflow definition with its steps to reference-data/workflows.ts; implement an ApprovalHandler (onApproved, onRejected, optional onWithdrawn) and register it with WorkflowService.registerHandler in onModuleInit; raise requests with WorkflowService.submit inside the business transaction.
Add a business parameter	Add the key and default (with range) to modules/settings/setting-keys.ts; read it through SettingsService; defaults are seeded at start-up.
Add a scheduled job	Use @Cron or @Interval with timeZone BUSINESS_TIME_ZONE, return early when JOBS_ENABLED is false, and wrap the work in prisma.withJobLock('<job-name>', ...).

Table 21: Common development tasks

16. Handover Checklist

Item	Evidence	Owner	Done
Source code repository with full history transferred to IIFT/IITH	Repository access confirmed	iorta	☐
Production, UAT and SIT environments documented with access granted	Access matrix	iorta, IITH	☐
Secrets and keys held in the IITH vault; no copies outside	Vault inventory signed	IITH, iorta	☐
Monitoring dashboards and alert rules live; alert recipients tested	Test alert received	iorta	☐
Backups running; one restore tested and reconciled	Restore test record	IITH, iorta	☐
DR replication running; DR test plan agreed	Plan approved	IITH, iorta	☐
Runbooks in this document executed once in UAT by IIFT/IITH staff	Signed runbook log	IIFT, iorta	☐
Knowledge-transfer sessions delivered and attended	Attendance and feedback	iorta	☐
Escalation contacts completed and tested	Contact test record	IIFT, iorta	☐
Known-error list and open defect list handed over	Lists accepted	iorta	☐
Data Dictionary and Solution Architecture at the go-live version	Documents issued	iorta	☐
Hypercare exit criteria met: no open P1/P2, EOD stable 10 business days	Hypercare report	iorta, IIFT	☐

Table 22: Handover checklist

Role	Name	Signature / date
IIFT application owner	[Name]	
IITH infrastructure lead	[Name]	
iorta TechNXT project director	[Name]	

Table 23: Handover acceptance

17. Monthly Service Report Template

Issued by the 10th business day of each month (MNT-25) and reviewed in the quarterly service review (MNT-26).

#	Section	Content
1	Summary	Service status, key events, availability, SLA attainment, actions for IIFT
2	Availability	Monthly availability overall and in business hours against 99.5% and 99.9%; outages with cause and duration
3	Incidents	Opened, resolved and open by priority; SLA attainment per priority; P1/P2 summaries
4	Problems	Root-cause analyses completed and actions outstanding
5	Service requests	Volume by type, average turnaround
6	Changes and releases	Changes implemented, emergency changes, releases with content
7	Security	Patches applied, vulnerabilities found and remediation status, access reviews
8	Operations	EOD runs, reconciliation results, integration dead-letters, backup and restore tests
9	Capacity	Database and document growth, CPU and memory trends against sizing
10	Enhancement hours	Hours used from the annual 60-hour pool, balance
11	Outstanding items and plan	Open issues, upcoming changes, next month's plan

Table 24: Report sections

Measure	Target	This month	Previous month
Availability overall	99.5%	[x.x%]	[x.x%]
Availability in business hours	99.9%	[x.x%]	[x.x%]
P1 responded in 30 min / restored in 4 h	100%	[n of n]	[n of n]
P2 responded in 2 h / resolved in 1 business day	95%	[n of n]	[n of n]
P3 within SLA	90%	[n of n]	[n of n]
EOD runs completed on schedule	All business days	[n of n]	[n of n]
Reconciliations MATCHED	All	[n of n]	[n of n]
Dead-letter messages (open at month end)	0	[n]	[n]
Backups successful / restore test done	All / quarterly	[n of n / date]	[-]
Database size / document store size	Within sizing	[GB / GB]	[GB / GB]
Enhancement hours used (year to date)	60 per year	[h]	[h]

Table 25: KPI table

18. Exit and Transition Plan

Exit assistance is included in Year 5 and on termination (COM-19, MNT-30). IIFT owns its data, the configuration and the custom code delivered under the contract.

Element	Commitment
Trigger	Year 5 of maintenance, or within 30 days of a termination notice
Exit plan	Scope, timeline, receiving party and responsibilities agreed with IIFT
Knowledge transfer	Sessions on architecture, code, configuration, operations and known issues to the new provider or IIFT team (sessions 1 to 8 repeated as needed)
Documentation	Final update of this document, the Solution Architecture, Data Dictionary, administrator and user manuals

Element	Commitment
Source code and tooling	Final source code, pipeline definitions, deployment files and build scripts; container images in the IITH registry
Data	IIFT owns all data. Full export on request: PostgreSQL dump, CSV per table, document files decrypted into a folder per owner, audit trail
Credentials	All iorta access removed; secrets rotated by IITH after transfer
Parallel support	Shadow support to the new provider for up to 30 days
Closure	Signed transition acceptance; secure deletion of IIFT data held by iorta, with certificate

Table 26: Exit and transition